

ENCUESTA INTEGRAL DE CIBERSEGURIDAD EN SISTEMAS DE IA

ESPAÑA 2026 — MITRE ATLAS | Modelo Detallado

Versión: 2.0 Completa

Clasificación: Público - Implementación

Fecha: Enero 2026

PARTE A: MODELO DE ENCUESTA INTEGRAL

Resumen Ejecutivo

Objetivo: Diagnosticar madurez ciberseguridad IA en 400-600 organizaciones españolas mediante encuesta estructurada de 140+ preguntas (13 módulos, escala Likert 1-5).

Población target:

- CISOs, responsables seguridad, auditores internos
- Todos los sectores (7): Financiero, Manufactura, Telecom, Salud, Energía, Defensa, Educación
- Todos los tamaños: PYME, Mediana, Grande
- Estimado: n=400-600 respondentes

Duración: 35-45 minutos por respondente

Idioma: Español (España) riguroso

Formato: Google Forms / Jotform online

RGPD: Cumplimiento total (consentimiento, anonimización, retención)

MÓDULO 1: GOBERNANZA Y ESTRATEGIA IA (6 preguntas)

Sección 1.1: Estructura Gobernanza IA

M1.Q1: ¿Su organización tiene definida una **política formal de ciberseguridad para sistemas IA**?

- 1: No existe
- 2: Borrador/en desarrollo
- 3: Política aprobada, no implementada
- 4: Política implementada, monitoreo parcial
- 5: Política implementada, monitoreo completo y revisión anual

M1.Q2: ¿Existe un **CISO o responsable ciberseguridad con dedicación específica a sistemas IA**?

- 1: No existe rol específico
- 2: Responsable designado, tiempo parcial (<25%)
- 3: Responsable dedicado, pero sin reportar a board
- 4: CISO IA dedicado, reporta a CEO/CTO
- 5: CISO IA + equipo especializado (>5 FTE), reporting ejecutivo

M1.Q3: ¿Se realizan auditorías internas de ciberseguridad IA con periodicidad establecida?

- 1: Nunca
- 2: Ad-hoc, sin calendario
- 3: Anual
- 4: Semestral
- 5: Trimestral o más frecuente

M1.Q4: ¿Se ha asignado presupuesto específico para ciberseguridad de sistemas IA (diferenciado de presupuesto ciberseguridad general)?

- 1: No existe presupuesto específico
- 2: <€50k/año
- 3: €50-200k/año
- 4: €200-500k/año
- 5: >€500k/año

M1.Q5: ¿Su organización tiene plan de transformación digital IA con objetivos ciberseguridad explícitos para 2026-2027?

- 1: No existe plan
- 2: Plan general IA, sin ciberseguridad específica
- 3: Plan IA + objetivos seguridad generales
- 4: Plan detallado IA + objetivos seguridad específicos, sin métricas
- 5: Plan detallado + objetivos medibles + KPIs establecidos

M1.Q6: ¿Se realizan evaluaciones de riesgo adversarial específicas para sistemas IA alto-riesgo conforme AI Act EU?

- 1: No se realizan
- 2: Evaluaciones genéricas, no específico IA
- 3: Evaluaciones IA, enfoque reactivo
- 4: Evaluaciones IA anuales, enfoque proactivo
- 5: Evaluaciones trimestrales + testing adversarial continuo

MÓDULO 2: GESTIÓN DE ACTIVOS IA (5 preguntas)

Sección 2.1: Inventario y Mapeo

M2.Q1: ¿Tiene su organización un inventario completo y actualizado de todos los sistemas IA en producción?

- 1: No existe inventario
- 2: Inventario parcial (<50% cobertura)
- 3: Inventario ~80%, actualización anual
- 4: Inventario >95%, actualización trimestral
- 5: Inventario 100%, actualización en tiempo real (automatizado)

M2.Q2: ¿Se ha mapeado la **criticidad de cada sistema IA** (impacto potencial si comprometido)?

- 1: No existe mapeo
- 2: Clasificación informal/cualitativa
- 3: Clasificación formal (crítica/media/baja), no documentada
- 4: Clasificación documentada, actualización anual
- 5: Clasificación cuantitativa (matriz impacto/probabilidad), actualización continua

M2.Q3: ¿Se documentan las **dependencias entre sistemas IA y sistemas legacy** (bases datos, APIs, infraestructura)?

- 1: No se documentan
- 2: Documentación informal, incompleta
- 3: Documentación formal, 70% cobertura
- 4: Documentación 95%, actualización semestral
- 5: Mapeo completo automatizado, actualización en tiempo real

M2.Q4: ¿Se realiza **análisis de supply chain para modelos IA y librerías de terceros**?

- 1: No se realiza
- 2: Revisión ad-hoc, sin proceso formal
- 3: Proceso formal, documentación básica
- 4: Análisis profundo (SBOM), actualización anual
- 5: Análisis SBOM continuo, validación de proveedores trimestral

M2.Q5: ¿Se mantiene un registro de **datos de entrenamiento** (origen, calidad, validación) para modelos IA en producción?

- 1: No existe registro
- 2: Registro informal/parcial
- 3: Registro formalizado, <80% cobertura
- 4: Registro completo, auditoría anual
- 5: Registro completo + validación continua de data quality

MÓDULO 3: IDENTIFICACIÓN DE VULNERABILIDADES IA (7 preguntas)

Sección 3.1: Testing y Adversarial

M3.Q1: ¿Se realizan pruebas de adversarial robustness (ej. adversarial examples, perturbaciones) contra sus modelos IA principales?

- 1: Nunca
- 2: Esporádicamente, sin formalidad
- 3: Incluidas en testing antes producción
- 4: Testing adversarial continuo, reportes mensuales
- 5: Red team dedicado, testing continuo + automatización

M3.Q2: ¿Se evalúa la **susceptibilidad a ataques de inyección** (prompt injection, command injection) en sistemas de IA (ej. LLMs)?

- 1: No se evalúa
- 2: Revisión manual ad-hoc
- 3: Testing incluido en QA, no específico
- 4: Testing específico prompt injection, 80% cobertura
- 5: Testing automatizado 100%, regeneración de test cases mensual

M3.Q3: ¿Existe un proceso para identificar y mitigar **sesgos discriminatorios** en modelos IA?

- 1: No existe proceso
- 2: Revisión manual, casos aislados
- 3: Proceso formal, documentación básica
- 4: Evaluación de sesgos pre-producción, auditoría anual
- 5: Monitoring continuo de sesgos, dashboard metrices fairness

M3.Q4: ¿Se realiza **análisis de envenenamiento de datos de entrenamiento** (data poisoning)?

- 1: No se realiza
- 2: Revisión cualitativa sin formalidad
- 3: Validación básica de calidad datos
- 4: Análisis formal, procedimientos de detección
- 5: Monitoreo continuo con alertas automáticas

M3.Q5: ¿Se documentan y categorizan todos los **incidentes de seguridad relacionados con IA**?

- 1: No se documentan
- 2: Documentación informal/incompleta
- 3: Registro formal, 70% de incidentes capturados
- 4: Documentación 95%, análisis post-mortem formales
- 5: 100% capturados, análisis inmediato, lecciones aprendidas implementadas

M3.Q6: ¿Se realiza **auditoría externa independiente** de sistemas IA (por terceros especializados)?

- 1: Nunca
- 2: Ad-hoc, sin regularidad
- 3: Anual
- 4: Semestral
- 5: Trimestral o más frecuente

M3.Q7: ¿Se aplica **fuzzing y testing de robustez** a APIs y interfaces de sistemas IA?

- 1: No se aplica
- 2: Testing manual ocasional
- 3: Incluido en testing pre-producción
- 4: Fuzzing automatizado, resultados documentados
- 5: Fuzzing continuo, integrado en CI/CD

MÓDULO 4: PROTECCIÓN Y CONTROL DE ACCESO (6 preguntas)

Sección 4.1: Defensas Técnicas

M4.Q1: ¿Se implementan **controles de acceso basado en roles (RBAC)** para sistemas IA (quién accede a modelos, datos, APIs)?

- 1: No existe control
- 2: Control básico (usuarios/administradores)
- 3: RBAC implementado parcialmente
- 4: RBAC completo, auditoría anual
- 5: RBAC + atributos (ABAC), monitoreo continuo

M4.Q2: ¿Se **encriptan modelos IA en reposo y en tránsito**?

- 1: No se encriptan
- 2: Encriptación parcial (solo en tránsito)
- 3: Encriptación en reposo + tránsito, estándar básico
- 4: Encriptación en reposo + tránsito, estándares fuertes (AES-256)
- 5: Encriptación end-to-end + key rotation automatizada

M4.Q3: ¿Se implementan **firewalls y segmentación de red** para aislar sistemas IA de otros sistemas?

- 1: No existe segmentación
- 2: Segmentación básica (DMZ)
- 3: Segmentación por función, no IA-específica
- 4: Segmentación específica IA, reglas firewall documentadas
- 5: Zero-trust segmentation, microsegmentación IA

M4.Q4: ¿Se utiliza **logging centralizado y auditoría de acceso** (quién accedió, qué hizo, cuándo)?

- 1: No existe logging
- 2: Logging local, sin centralización
- 3: Logging centralizado, retención <90 días
- 4: Logging centralizado SIEM, 1+ años retención
- 5: Logging + análisis correlación automática, alertas reales-time

M4.Q5: ¿Se implementan **controles de integridad de modelos** (detección de modificaciones, backups, versionado)?

- 1: No existe control
- 2: Backups manuales ocasionales
- 3: Versionado implementado, backups automáticos
- 4: Versionado + checksums, integridad verificada pre-ejecución
- 5: Versionado + blockchain/hash chains, monitoreo continuo

M4.Q6: ¿Se aplican **rate limiting y throttling** en APIs de sistemas IA para prevenir abuso?

- 1: No se aplica
- 2: Rate limiting básico por IP

- 3: Rate limiting por usuario/API key
- 4: Throttling inteligente (por consumo, ML-based)
- 5: Rate limiting + análisis de anomalías, ajuste dinámico

MÓDULO 5: MONITOREO Y SIEM (5 preguntas)

Sección 5.1: Capacidades Detección

M5.Q1: ¿Tiene su organización un SIEM (Security Information and Event Management) implementado?

- 1: No existe SIEM
- 2: SIEM en piloto/parcial
- 3: SIEM operativo, cobertura <70%
- 4: SIEM operativo, cobertura >90%
- 5: SIEM + SOAR (automatización), cobertura 100%

M5.Q2: ¿Se generan alertas automáticas para actividades sospechosas en sistemas IA (anomalías, patrones conocidos)?

- 1: No existen alertas
- 2: Alertas manuales basadas en reglas simples
- 3: Alertas automáticas, <50% de amenazas detectadas
- 4: Alertas 70-90% de amenazas, false positive rate ~20%
- 5: Alertas 95%+ amenazas, false positive <5%, ML-powered

M5.Q3: ¿Se realiza análisis de comportamiento de usuarios/entidades (UEBA) para detección de anomalías?

- 1: No existe UEBA
- 2: Análisis manual ocasional
- 3: UEBA básico, detección de cambios de patrón
- 4: UEBA avanzado, perfilado de comportamiento por rol
- 5: UEBA + ML-based, detección de actividades insider threat

M5.Q4: ¿Se calcula y rastrea el MTTD (Mean Time To Detect) de incidentes IA?

- 1: No se calcula
- 2: Cálculo ad-hoc, sin métrica formal
- 3: MTTD calculado, ~8-12 horas promedio
- 4: MTTD documentado, <4 horas objetivo
- 5: MTTD <2 horas, automatizado, reporting diario

M5.Q5: ¿Se integra threat intelligence (feeds de amenazas IA-specific) en sistemas detección?

- 1: No se integra
- 2: Feeds genéricas de ciberseguridad
- 3: Feeds IA-specific públicas (ej. MITRE ATLAS)

- 4: Feeds IA-specific + feeds propietarias, actualización diaria
- 5: Feeds multiples con correlación automática, actualización hora real

MÓDULO 6: RESPUESTA A INCIDENTES IA (5 preguntas)

Sección 6.1: Plans y Procedimientos

M6.Q1: ¿Existe un plan formal de respuesta a incidentes (IRP) específico para sistemas IA?

- 1: No existe plan IA-específico
- 2: Plan genérico ciberseguridad, aplica también a IA
- 3: Plan IA en desarrollo
- 4: Plan IA formal documentado, simulacros anuales
- 5: Plan IA + playbooks por tipo ataque, simulacros trimestrales

M6.Q2: ¿Se han identificado escalas de severidad para incidentes IA (cómo se clasifican y prioriza respuesta)?

- 1: No existen escalas
- 2: Escalas genéricas (no IA-specific)
- 3: Escalas IA básicas
- 4: Escalas IA con criterios cuantitativos
- 5: Escalas + matriz de impacto automatizada, decisiones en tiempo real

M6.Q3: ¿Se reportan incidentes IA a autoridades regulatorias (AESIA, DPA) dentro del plazo requerido?

- 1: No se reportan
- 2: Reportes ad-hoc, sin proceso
- 3: Proceso formal, reportes >72h
- 4: Reportes <72h, conforme NIS2
- 5: Reportes <24h, análisis root cause automático

M6.Q4: ¿Se realiza análisis post-mortem (post-incident review) de incidentes IA?

- 1: No se realiza
- 2: Análisis informal, documentación mínima
- 3: Análisis formal documentado
- 4: Análisis 72h post-incidente, lecciones implementadas
- 5: Análisis inmediato, proceso continuo de mejora, tracking de acciones

M6.Q5: ¿Existe un equipo dedicado a respuesta de incidentes IA (CSIRT IA o equivalente)?

- 1: No existe equipo
- 2: Roles de respuesta no dedicados
- 3: Equipo dedicado a tiempo parcial
- 4: Equipo CSIRT dedicado, 24/5 disponibilidad
- 5: Equipo CSIRT 24/7, especialización alta, certificaciones

MÓDULO 7: CONTROL DE ACCESO Y AUTENTICACIÓN (5 preguntas)

Sección 7.1: Identidad y Acceso

M7.Q1: ¿Se implementa **autenticación multifactor (MFA)** para acceso a sistemas IA?

- 1: No existe MFA
- 2: MFA para administradores, no usuarios finales
- 3: MFA parcial (50% usuarios)
- 4: MFA 95%+ usuarios, métodos diversos
- 5: MFA 100% + biometría/hardware keys

M7.Q2: ¿Se gestionan **credenciales/API keys de forma segura** (rotación, vault centralizado)?

- 1: No existe gestión formalizada
- 2: Gestión manual, rotación ad-hoc
- 3: Gestión en vault, rotación anual
- 4: Gestión centralizada, rotación trimestral, auditoría continua
- 5: Gestión automatizada, rotación semanal/automática

M7.Q3: ¿Se aplica el principio de **least privilege (mínimos permisos necesarios)** para acceso sistemas IA?

- 1: No se aplica
- 2: Aplicación informal
- 3: Documentado, implementado 70%
- 4: Implementado 95%, revisión anual
- 5: Automatizado, revisión trimestral, just-in-time access

M7.Q4: ¿Se segregan **roles y responsabilidades** (ej. desarrollador ≠ deployer ≠ auditor)?

- 1: No existe segregación
- 2: Segregación informal
- 3: Segregación documentada, 80% cumplimiento
- 4: Segregación 100%, matriz RACI formal
- 5: Segregación + automatización, monitoreo continuo de violaciones

M7.Q5: ¿Se realizan **auditorías de acceso** (quién tiene acceso a qué) con regularidad?

- 1: No se realizan
- 2: Auditoría anual
- 3: Auditoría semestral
- 4: Auditoría trimestral, generación de reportes
- 5: Auditoría continua automatizada, alertas de anomalías

MÓDULO 8: DEFENSA ESPECÍFICA MITRE ATLAS (7 preguntas)

Sección 8.1: Tácticas y Técnicas ATLAS

M8.Q1: ¿Se han mapeado los sistemas IA de su organización contra las **15 tácticas de MITRE ATLAS**?

- 1: No se conoce MITRE ATLAS
- 2: Conocimiento informal de MITRE ATLAS
- 3: Mapeo parcial realizado
- 4: Mapeo formal documentado
- 5: Mapeo completo con evaluación de técnicas específicas

M8.Q2: ¿Se han identificado **técnicas MITRE ATLAS** que constituyen mayor riesgo para su contexto?

- 1: No se han identificado
- 2: Identificación informal
- 3: Lista de técnicas críticas documentada
- 4: Matriz de criticidad (probabilidad × impacto)
- 5: Matriz + análisis de variantes contexto-específico

M8.Q3: ¿Se han implementado **defensas específicas contra ataques adversariales** (ej. input validation, adversarial training)?

- 1: No existen defensas específicas
- 2: Defensas genéricas que pueden mitigar
- 3: Defensas específicas parcialmente implementadas
- 4: Defensas implementadas para técnicas críticas
- 5: Suite completa defensas + testing continuo

M8.Q4: ¿Se realiza **red teaming/penetration testing específico a modelos IA y arquitecturas**?

- 1: No se realiza
- 2: Red teaming genérico
- 3: Red teaming con enfoque IA parcial
- 4: Red teaming IA formal, reportes trimestrales
- 5: Red team dedicado interno + externo, testing continuo

M8.Q5: ¿Se mantiene una **matriz de técnicas ATLAS vs. controles implementados**?

- 1: No existe matriz
- 2: Matriz informal/ad-hoc
- 3: Matriz formal, documentada
- 4: Matriz documentada, actualización anual
- 5: Matriz centralizada, actualización continua, gaps identificados automáticamente

M8.Q6: ¿Se implementa **seguridad en el modelo/pipeline de ML** (Model Risk Management)?

- 1: No existe MRM
- 2: MRM genérico
- 3: MRM específico, documentado parcialmente

- 4: MRM formal, procesos de validación pre-producción
- 5: MRM automatizado, monitoreo continuo del modelo post-producción

M8.Q7: ¿Se realiza **análisis de explicabilidad (XAI)** del modelo para detección de anomalías?

- 1: No se realiza
- 2: Análisis manual ocasional
- 3: Herramientas XAI básicas implementadas
- 4: XAI integrado en pipeline, reportes formales
- 5: XAI automatizado, interpretabilidad en tiempo real

MÓDULO 9: SUPPLY CHAIN Y PROVEEDORES (5 preguntas)

Sección 9.1: Terceros y Riesgos Externos

M9.Q1: ¿Se realizan **evaluaciones de seguridad a proveedores de IA** (librerías, modelos pre-trained, plataformas)?

- 1: No se realizan
- 2: Evaluaciones ad-hoc informales
- 3: Cuestionario formal de seguridad
- 4: Evaluación profunda (auditoría, testing)
- 5: Evaluación continua + contrato SLAs seguridad

M9.Q2: ¿Se analizan las **dependencias de software (SBOM - Software Bill of Materials)** de sistemas IA?

- 1: No se analiza
- 2: Análisis manual ocasional
- 3: SBOM generado, revisión manual
- 4: SBOM automatizado, auditoría de vulnerabilidades
- 5: SBOM continuo + vulnerability scanning automatizado

M9.Q3: ¿Se establecen **cláusulas de seguridad en contratos con proveedores IA**?

- 1: No se establecen
- 2: Cláusulas genéricas
- 3: Cláusulas seguridad básicas incluidas
- 4: Cláusulas seguridad detalladas, compliance requerido
- 5: Cláusulas + auditabilidad incluida + SLAs seguridad

M9.Q4: ¿Se realiza **gestión de riesgos de proveedores terceros** (continuidad, cambios, escalabilidad)?

- 1: No existe gestión
- 2: Gestión informal
- 3: Proceso formal documentado
- 4: Risk matrix documentada, planes mitigación
- 5: Gestión automatizada, alertas de cambios críticos

M9.Q5: ¿Se han identificado **proveedores críticos** cuya indisponibilidad impactaría sistemas IA?

- 1: No se han identificado
- 2: Identificación informal
- 3: Lista documentada, sin planes contingencia
- 4: Lista + planes de contingencia formal
- 5: Planes + redundancia/fallover implementada

MÓDULO 10: REGULATORIO Y CONFORMIDAD (6 preguntas)

Sección 10.1: AI Act, NIS2, AIDA

M10.Q1: ¿Se ha realizado una **evaluación de conformidad con AI Act EU** (sistemas clasificados alto-riesgo)?

- 1: No se ha realizado
- 2: Evaluación informal
- 3: Evaluación formal, documentación parcial
- 4: Evaluación completa, conformidad documentada
- 5: Evaluación + auditoría externa, certificación

M10.Q2: ¿Se implementan los **100 controles de NIS2** aplicables a su organización?

- 1: <25% implementado
- 2: 25-50% implementado
- 3: 50-75% implementado
- 4: 75-90% implementado
- 5: >90% implementado + auditoría anual

M10.Q3: ¿Se cumple con **requisitos AIDA** (transparencia, rendición cuentas, prohibiciones)?

- 1: No se cumple
- 2: Cumplimiento parcial (<50%)
- 3: Cumplimiento ~70%
- 4: Cumplimiento >90%
- 5: Cumplimiento 100% + documentación pública

M10.Q4: ¿Se respetan **derechos RGPD en procesamiento de datos IA** (consentimiento, derecho olvido)?

- 1: No se respetan
- 2: Respeto parcial
- 3: Controles implementados, auditoría anual
- 4: Controles + DPA involucrado, auditoría continua
- 5: Cumplimiento total, privacy by design

M10.Q5: ¿Se han realizado **auditorías de cumplimiento normativo** por terceros independientes?

- 1: No se han realizado
- 2: Auditorías internas solo

- 3: Auditoría externa anual
- 4: Auditorías externas semestrales + auditoría AESIA
- 5: Auditorías continuas + certificaciones internacionales

M10.Q6: ¿Se ha designado un **Data Protection Officer (DPO) o responsable conformidad IA?**

- 1: No existe designación
- 2: Responsable ad-hoc (sin dedicación)
- 3: Responsable a tiempo parcial
- 4: DPO dedicado + asesor IA
- 5: Equipo especializado (DPO, asesor IA, auditor)

MÓDULO 11: CAPACITACIÓN Y CONCIENCIA (5 preguntas)

Sección 11.1: Formación Continua

M11.Q1: ¿Se proporciona **capacitación en ciberseguridad IA al personal técnico (data scientists, ingenieros ML)?**

- 1: No existe capacitación
- 2: Capacitación genérica, no IA-específica
- 3: Capacitación IA básica, ad-hoc
- 4: Capacitación IA estructurada, anual
- 5: Capacitación IA continua, certificaciones especializadas

M11.Q2: ¿Se realizan **simulacros de phishing/social engineering dirigidos a empleados IA?**

- 1: No se realizan
- 2: Simulacros genéricos ocasionales
- 3: Simulacros específicos IA, anual
- 4: Simulacros trimestrales, reporting de resultados
- 5: Simulacros mensuales + micro-learning continuo

M11.Q3: ¿Existe un programa de **conciencia sobre riesgos de IA (para ejecutivos, boards)?**

- 1: No existe programa
- 2: Comunicaciones ad-hoc
- 3: Programa formal anual
- 4: Programa trimestral, involucramiento board
- 5: Programa continuo, KPIs de conciencia medidos

M11.Q4: ¿Se documentan y comunican **lecciones aprendidas de incidentes IA?**

- 1: No se documentan
- 2: Documentación informal
- 3: Lecciones formales, compartidas internamente
- 4: Lecciones compartidas + acciones implementadas
- 5: Lecciones compartidas + tracking de acciones + capacitación

M11.Q5: ¿Se mantiene un **registro de certificaciones en seguridad IA** del personal?

- 1: No se mantiene
- 2: Registro informal
- 3: Registro formal, actualización anual
- 4: Registro + planes desarrollo individuales
- 5: Programa de carrera especializado con certificaciones requeridas

MÓDULO 12: CONTINUIDAD Y RECUPERACIÓN (4 preguntas)

Sección 12.1: Business Continuity

M12.Q1: ¿Existe un **plan de contingencia/disaster recovery** específico para sistemas IA?

- 1: No existe plan
- 2: Plan genérico IT, aplica a IA
- 3: Plan IA en desarrollo
- 4: Plan IA formal documentado
- 5: Plan IA + validación anual mediante simulacros

M12.Q2: ¿Se realizan **backups regulares de modelos IA y datos de entrenamiento**?

- 1: No se realizan backups
- 2: Backups manuales ocasionales
- 3: Backups automatizados mensual
- 4: Backups semanales, almacenamiento redundante
- 5: Backups diarios + replicación geográfica, RTO <1h

M12.Q3: ¿Se ha calculado el **RTO (Recovery Time Objective)** y **RPO (Recovery Point Objective)** para sistemas IA críticos?

- 1: No se ha calculado
- 2: Estimaciones informales
- 3: Valores documentados, no validados
- 4: Valores documentados, validados anualmente
- 5: Valores documentados + testing continuo de cumplimiento

M12.Q4: ¿Existe un **runbook de recuperación ante incidentes catastróficos** en sistemas IA?

- 1: No existe runbook
- 2: Runbook genérico
- 3: Runbook IA básico documentado
- 4: Runbook IA detallado, simulacros anuales
- 5: Runbook IA + automatización, validación trimestral

MÓDULO 13: EVALUACIÓN RIESGO INTEGRAL IA (4 preguntas)

Sección 13.1: Riesgo Agregado

M13.Q1: ¿Se ha realizado un **risk assessment integral de sistemas IA** siguiendo marco como FAIR o CAsPeA?

- 1: No se ha realizado
- 2: Evaluación informal/cualitativa
- 3: Evaluación formal con scoring
- 4: Risk assessment documentado, actualización anual
- 5: Risk assessment automatizado, actualización continua

M13.Q2: ¿Se ha calculado una **métrica de exposición económica potencial (pérdida esperada anual - ALE)** por incidente IA?

- 1: No se ha calculado
- 2: Estimaciones informales
- 3: Estimaciones formales documentadas
- 4: ALE por sistema documentado
- 5: ALE agregado + proyecciones de mejora tras inversiones

M13.Q3: ¿Se realiza un **seguimiento de indicadores clave de riesgo IA (KRIs)** a nivel ejecutivo/board?

- 1: No se realiza seguimiento
- 2: Seguimiento informal
- 3: KRIs identificados, reporting anual
- 4: KRIs documentados, reporting trimestral
- 5: KRIs automatizados, dashboard tiempo real, alertas

M13.Q4: ¿Se utiliza algún modelo de madurez** (ej. CMMC 2.0, SAMM, o modelo propio) para evaluar posición ciberseguridad IA?

- 1: No se utiliza modelo
- 2: Modelo genérico aplicado ad-hoc
- 3: Modelo formal seleccionado
- 4: Modelo implementado, auto-evaluación anual
- 5: Modelo implementado + auditoría externa anual

SECCIÓN FINAL: OBSERVACIONES Y CONTEXTO

01. Principales desafíos para ciberseguridad en sistemas IA (texto libre, 500 caracteres):

02. Inversión planificada en ciberseguridad IA 2026 (euros, aproximado):

- [] Sin inversión planeada
- [] <€50k
- [] €50-200k

- ☐ €200-500k
- ☐ >€500k

03. Obstáculos principales para implementación (múltiple selección):

- ☐ Presupuesto insuficiente
- ☐ Falta de talento especializado
- ☐ Complejidad técnica
- ☐ Requisitos normativos poco claros
- ☐ Resistencia organizacional
- ☐ Falta de liderazgo ejecutivo
- ☐ Otros (especificar):

04. ¿Autoriza compartir datos anonimizados para análisis nacional?

- ☐ Sí, completamente
- ☐ Sí, parcialmente
- ☐ No
- ☐ Solicitar antes de compartir

CONCLUSIÓN ENCUESTA

Agradecemos su participación en esta encuesta inaugural de ciberseguridad IA en España.

Próximos pasos:

- Recibirá reporte personalizado (score 0-100 + benchmarking) en 4-6 semanas
- Acceso a reporte nacional anonimizado (junio 2026)
- Invitación a evento de networking con pares similares

Línea de soporte: encuesta@mitrelatlas.es

ESTADÍSTICAS ENCUESTA

- Total preguntas: 140
- Escala: Likert 1-5 (No implementado / Iniciado / Intermedio / Maduro / Optimizado)
- Módulos: 13 + sección abierta
- Duración estimada: 38 minutos (media)
- RGPD: Cumplimiento total
- Idioma: Español (España)
- Formato: Online (Google Forms / Jotform)

Versión Encuesta: 2.0 Completa

Preparada: Enero 2026

Clasificación: Público - Implementación